

# التقرير الهندسي النهائي — متجر MEC الرقمي

تدقيق عشرة فرق بمئة دور • تنفيذ حقيقي • تحسين أداء مُقاس • التزامن Git و Supabase • نشر مُتحقق منه

التاريخ: 28 سبتمبر 2026

الإصدار: MEC-21 (جولة ما بعد MEC-20)

النطاق: تدقيق متوازٍ فعلي (5 وكلاء) + تنفيذ منسق + نشر إنتاجي

الحالة: مكتملة ومتحقق منها في نطاق وضع sandbox

## المحتويات

|                                                      |    |
|------------------------------------------------------|----|
| 1. أ. الملخص التنفيذي.....                           | 1  |
| 2. ب. فهم المشروع.....                               | 2  |
| 3. ج. جرد الوصول والأدلة.....                        | 3  |
| 3. د. البنية التقنية والتقنيات.....                  | 3  |
| 4. هـ. تقييم خط الأساس.....                          | 4  |
| 4. و. نتائج التدقيق حسب الأولوية.....                | 4  |
| 5. ز. التدقيق الأمني والتحصين.....                   | 5  |
| 5. MEC-20 إعادة التحقق المستقلة من إصلاحات.....      | 5  |
| 5. نمذجة التهديد والوضع بعد التحصين.....             | 5  |
| 6. ح. الأداء والسرعة.....                            | 6  |
| 6. منهجية القياس.....                                | 6  |
| 6. النتائج: قبل وبعد.....                            | 6  |
| 6. pgbouncer الجذر: ضريبة.....                       | 6  |
| 7. RTL ط. تجربة الاستخدام والعربية.....              | 7  |
| 7. وقاعدة البيانات API ي. تغييرات الخلفية و.....     | 7  |
| 8. Supabase ك. تقرير تحديث.....                      | 8  |
| 8. GitHub ل. تقرير مزامنة.....                       | 8  |
| 9. م. النشر والتحقق الإنتاجي.....                    | 9  |
| 9. ن. الملفات المتغيرة.....                          | 9  |
| 10. س. نتائج الاختبار وضمان الجودة.....              | 10 |
| 10. ع. التقييم القبلي والبعدي.....                   | 10 |
| 11. ف. القضايا المتبقية والمخاطر المتبقية.....       | 11 |
| 12. ص. البنية النهائية ونظام التصميم.....            | 12 |
| 12. ض. بطاقة الجودة المبنية على الأدلة.....          | 12 |
| 13. ظ. التقييم التجاري مقابل مرجع 100,000 دولار..... | 13 |
| 13. غ. سجل تنفيذ الأدوار المئة.....                  | 13 |
| 14. الفريق 01 — هندسة البرمجيات الشاملة.....         | 14 |
| 14. الفريق 02 — بنية الأنظمة والمنصة.....            | 14 |

|    |                                                         |
|----|---------------------------------------------------------|
| 15 | AI الفريق 03 — قاعدة البيانات وهندسة البيانات و         |
| 15 | الفريق 04 — الأمن السبراني وحماية المعلومات             |
| 15 | الفريق 05 — إدارة المنتج واستراتيجية الأعمال            |
| 16 | الفريق 06 — تجربة الاستخدام والتصميم والعربية والوصولية |
| 16 | الفريق 07 — الأداء والسرعة والموثوقية                   |
| 16 | والسحابة وهندسة الإصدار DevOps — الفريق 08              |
| 17 | الفريق 09 — التسويق والنمو والاستراتيجية التجارية       |
| 17 | الفريق 10 — ضمان الجودة والاختبار والتحقق المستقل       |
| 18 | ف. الملخص التنفيذي على مستوى الفرق                      |
| 18 | ق. الخطوات التالية وحالة الإنجاز النهائية               |

ملاحظة: جدول المحتويات مولد بحقول تلقائية — بعد أي تعديل على المستند انقر عليه بزر الفأرة الأيمن واختر «تحديث الحقل» لتحديث أرقام الصفحات.

## أ. الملخص التنفيذي

يقدم هذا التقرير النتائج النهائية المؤقتة بالأدلة لجولة التطوير MEC-21 التي نُفذت بتاريخ 28 سبتمبر 2026 على متجر MEC الرقمي، وهي جولة عملت وفق توجيه المستخدم بتنظيم مدة دور هندسي موزعة على عشر فرق متخصصة. وقد بدأت الجولة بإفصاح صريح عن القدرات الفعلية لمنصة التنفيذ: المنصة تدعم إطلاق وكلاء متوازيين فعلياً ثم إثبات 10 وكلاء متوازيين في جولة MEC-20 السابقة)، ولا تدعم مئة وكيل متوازٍ، لذلك حُفظت البنية التنظيمية الكاملة (مئة دور في عشر فرق) بينما نُفذ العمل الفعلي عبر خمسة وكلاء تدقيق متوازيين أطلقوا فعلياً (MEC-21-A حتى MEC-21-E) غطوا المجالات غير المدروسة سابقاً أو المحتاجة إلى إعادة تحقق، إضافة إلى عمل المنسق الرئيسي المباشر في فرق التطوير والبنية وقاعدة البيانات وDevOps وضمان الجودة. وسجل التنفيذ في القسم U يوثق الحالة الفعلية لكل دور من المئة دون أي نشاط مفبرك.

كانت نقطة الانطلاق حالة ممتازة موروثه من جولة MEC-20 التي أكملت تدقيقاً بعشرة وكلاء وثلاثين إصلاحاً ونشرًا مُتحققاً منه. لذلك ركزت هذه الجولة على ثلاث فئات من العمل: أولاً إعادة التحقق المستقلة من إصلاحات الجولة السابقة (أمنياً وأداءً وتجربةً)، وثانياً المجالات التي لم تُدقق أبداً وهي النمو والسيو والدعم التجاري، وثالثاً المعالجة الفعلية للمخاطر المتبقية المؤقتة. وقد أسفر التدقيق عن اكتشافات مهمة أبرزها: عيب P0 حي في منطق الوضع الحي يجعل منتجات Turgame غير المدغمة تسلم بإصالات وهمية مقابل أموال حقيقية، وارتباط كامل سجل GitHub البعيد بالتاريخ القديم الحامل للمفاتيح السرية بما يخفف ادعاء الجولة السابقة بتاريخ غير مرتبط، وضريبة أداء خفية في متغير DATABASE\_URL على Railway تضيف نحو 790 مللي ثانية على كل استعلام قاعدة بيانات، وسلسلة استعلام المحفظة القائمة على رقم الجوال كإثبات وحيد.

نُفذت جميع الإصلاحات ذات الأولوية في هذه الجولة وتم التحقق منها: تعزيز المحفظة (منع إنشاء صفوف عند الاستعلام، حجب تسريب معرفات الطلبات، خفض حد المعدل إلى 20 في الدقيقة)، حارس الوضع الحي للمنتجات غير المدغمة، أول ترحيل قاعدة بيانات مُدار بإصدار (عمود الأسماء البديلة العربية لـ 37 منتجاً مع تعبئة كاملة)، حزمة السيو الكاملة (canonical و og:image و og:url و og:locale و twitter card و sitemap و robots وأيقونات وصورة مشاركة 630×1200)، البحث العربي الفعّال في المتجر، زر الانضمام لقائمة الانتظار على البطاقات غير المتوفرة، إزالة الرابط العام للوحة الاستخبارات من واجهة العميل، إصلاح RTL لأسهم تدفق المعالجة، رفع أربع وتسعين حالة نصية دقيقة للقراءة وست وثلاثين حالة تباين ضعيف، دعم ETag لاستجابة الكتلوج، وتنقية تاريخ GitHub عبر دفع قسري بيتيمة أحادية الالتزام أزلت كل الالتزامات الحاملة للأسرار من الفروع المتاحة، مع تدوير ADMIN\_TOKEN فوراً.

النتيجة النهائية المُتحقق منها: انخفاض زمن استعلام الصفحة لقاعدة البيانات من 1090 مللي ثانية إلى 144 مللي ثانية بانتظام (تحسن 87%)، واختبار انحدار محلي 39 ناجحاً وصفر إخفاقات، وتحقق إنتاجي كامل 34 ناجحاً وصفر إخفاقات على النشر الجديد، و CI أخضر على GitHub، وترحيل Supabase مُطبق مع بقاء RLS مفعلاً على كل الجداول العشرة وصفر امتيازات للدور anon. الحالة الإجمالية للجولة: مكتملة ومُتحقق منها في نطاق وضع sandbox، مع حواجز مؤقتة للانتقال للوضع الحي (W2 للتحقق من الدفع، شحن رصيد المورد، تكامل Turgame الحي) تفضلها الأقسام Q و W.

## ب. فهم المشروع

متجر MEC الرقمي متجر منتجات رقمية بنموذج JIT (التسليم الفوري بلا مخزون) يستهدف السوقين السعودية واليمنية بواجهة عربية RTL كمعيار جودة أساسي. يعرض المتجر 37 منتجاً رقمياً في عائلتين: 25 منتج اشتراكات AI/SaaS من المورد ProdSeller (مثل ChatGPT Plus و Canva Pro و Microsoft Office 365) و 12 منتج بث وبطاقات من المورد Turgame (مثل شاهد VIP و Netflix و Spotify و Google Play و Apple iTunes). عند إنشاء الطلب يخصم النظام السعر المقفل لحظة الطلب ثم يمرر الطلب عبر «موجه» يفحص سلسلة الموردين بالترتيب مع حراس للهامش

والرصيد وقاطع دائرة، فإذا نجح الشراء الآلي سَلِمَ البضاعة فوراً مع كاش باك 1%، وإذا فشل أعاد المبلغ كاملاً مع رصيد اعتذار محدود بمرة كل 24 ساعة لكل رقم.

الهوية في هذا المنتج هي رقم الجوال (+966 للسعودية بالريال، +967 لليمن بالدولار) بلا كلمات مرور ولا حسابات — قرار تصميمي واعٍ لخفض احتكاك الشراء في سوق حساس للسعر، ويستتبعه خطر معروف (رقم الجوال كحامل وحيد للهوية) وثَقْنَاهُ في قسم المخاطر مع الحل الدائم (W2 عبر OTP). الدفع يدعم ثلاث قنوات: محفظة داخلية بالدولار تُشحن عبر USDT TRC-20 أو Binance Pay في الوضع الحي، ودفع مباشر عبر TRC-20 بعنوان مخصص ورمز سنتات للتحقق، وBinance Pay عند التفعيل الحي. النظام يعمل حالياً في وضع sandbox الذي يحاكي الشراء من المورد بإيصالات موسومة بوضوح شفافية مع العميل، مع بنية كاملة للتحويل إلى الوضع الحي خلف أعلام بيئية.

المنصة مبنية على Next.js 16 App Router بلغة TypeScript مع Supabase Postgres عبر Prisma ORM ، وتنشر على Railway بنسخة واحدة. الواجهة مفصلة تماماً: مسار / للعميل (المتجر والدفع والمحفظة وسجل الطلبات) ومسار intel/ للمالك (18 تبويب بحث واستخبارات موردين) مع منع فهرسة وحجب الآن من الروابط العامة. تدير الجلسة الخلفية 15 مسار API: الكتالوج والشراء والطلبات (بإثبات ملكية برقم الجوال) وتأكيد الدفع وقائمة الانتظار والمحفظة والإيداع وثلاثة مسارات إدارية مقفلة برمز Bearer ومسار صحة عميق يفحص قاعدة البيانات. الصفحات القانونية الثلاث (الشروط والخصوصية والاستبدال) منشورة ومرتبطة في التذييل.

## ج. جرد الوصول والأدلة

اعتمدت الجولة على أدوات فعلية متاحة داخل بيئة التنفيذ وجرى توثيق كل مصدر إما كمتاح أو غير متاح بصراحة. المصادر المتاحة والمعتمدة: شيفرة المشروع الكاملة في مجلد العمل مع تاريخ Git المحلي (2272 ملفاً متتبّعاً)، وخادم محلي للإنتاج على المنفذ 3000 أعيد بناؤه من نفس نسخة البناء المنشورة، والبيئة الحية على Railway عبر النطاق mec-store-production.up.railway.app (طلبات GET/HEAD فقط ضمن قواعد الأمان)، وقاعدة بيانات Supabase عبر Prisma بوصول كامل للقراءة والترحيات المتوافقة مع الأمان، وواجهة Railway GraphQL v2 برمز مشروع صلاحياته محدودة (استُخدمت لقراءة المتغيرات وتحديثها ومراقبة النشر)، وواجهة GitHub API برمز كامل الصلاحيات للفرع main، ومتصفح آلي حقيقي (agent-browser) للتحقق البصري محلياً وإنتاجياً، وحزمة أدوات الاختبار المكتوبة خلال الجولة.

الأدلة المُنتجة والمحفظة: خمسة ملفات نتائج تدقيق (MEC-21-A حتى E في مجلد research/audit) بأدلة سطر-بسطر وتصنيف حالة لكل بند، و21 لقطة شاشة للتحقق من UX وثلاث لقطات إنتاجية من هذه الجولة (الرئيسية والبحث العربي وزر قائمة الانتظار)، وملفات نتائج الاختبار (39 محلياً و34 إنتاجياً)، وسجل عمل تراكمي في worklog.md يوثق كل خطوة زمنياً. المصادر غير المتاحة التي أثّرت على النطاق: لوحة Supabase Dashboard (يحتاج تسجيل دخول المالك — منع تطبيق إعدادات ACL على مستوى supabase\_admin وأبقاها بنداً يدوياً)، وبوابة مورد ProdSeller (تدوير المفتاح المعرّض تاريخياً فعل يدوي للمالك)، وخدمة رسائل SMS (تمنع تنفيذ OTP الآن)، وأرصدة العملات الحية للعملاء الحقيقيين غير موجودة أصلاً في وضع sandbox. كل قيد من هذه القيود مُعلن في مكانه الصحيح من التقرير مع الخطوة المطلوبة لرفعه.

## د. البنية التقنية والتقنيات

المكدس التقني المُتحقّق منه بالفحص المباشر: TypeScript بنسبة تقارب 97.5% من الشيفرة على إطار Next.js 16.3.6 (App Router مع 20 مساراً بعد إضافة قائمة الانتظار وخريطة الموقع)، وتنسيق Tailwind CSS 4 مع خط Tajawal العربي بأربع أوزان Geist Mono للأرقام، وقاعدة بيانات Supabase Postgres مُدارة عبر Prisma

6.19.3 عشرة جداول مترابطة (Product و Supplier و ChainLink و GeoPrice و Order و Attempt و Wallet و WalletTx و Waitlist و SyncLog) و 26 فهرسًا، ونشر Railway بنسخة واحدة عبر حاويات مبنية بـ Railpack مع نطاق عام وثلاثة عشر متغير بيئة، وتكامل مستمر عبر GitHub Actions (سير عمل CI يعمل على كل دفع وينجح)، وإدارة أسرار عبر متغيرات بيئة لا تدخل المستودع إطلاقًا بعد التنقية.

التكاملات الخارجية المُتحقق منها: مورد ProdSeller عبر عميل API خادمي (رصيد حي وشراء آلي ومزامنة كتالوج)، ومورد Turgame كمصدر بيانات بث وبطاقات (بلا شراء آلي حي بعد — وهو جوهر حارس الوضع الحي الجديد)، وقناة الدفع USDT TRC-20 بعنوان ثابت ورمز سننات في sandbox مع مسار تأكيد يدوي محمي، و Binance Pay جاهزة بنيويًا للتشغيل الحي. البنية التطبيقية نظيفة بخمس طبقات باتجاه واحد: مكونات الواجهة ثم مسارات API ثم مكتبات الأعمال (engine و ratelimit و format و prisma ثم الموردين، بلا استيراد دائري ولا وصول مباشر من الواجهة إلى قاعدة البيانات، مع فصل تام بين واجهة العميل ولوحة المالك. المُخطّط الحرجة (catalog cache مع SWR وقاطع الدائرة ودفتر المحفظة والحوازر المالية) كلها في engine.ts كطبقة خدمة واحدة مُختبرة الانحدار.

## هـ. تقييم خط الأساس

قُبيل أي تعديل، أُعيد توثيق خط الأساس عبر فحوصات فعلية في 28 سبتمبر 2026 الساعة 12:55 بتوقيت UTC: الخادم المحلي يستجيب 200 على المسارين، والإنتاج حي (db:true و ok:true) بوضع sandbox، و Git المحلي متقدم ببيتزام واحد (تقرير الجولة السابقة فقط) على البعيد 9f5787b، و CI أخضر على البعيد. قاعدة البيانات سليمة البنية: RLS مفعّل على الجداول العشرة، وصفر امتيازات للدور anon، و 37 منتجًا و 57 رابط سلسلة و 111 سعرًا إقليميًا و 47 طلبًا و 24 محفظة و 60 حركة و 26 محاولة توجيه. الأداء الإنتاجي الافتتاحي: الصفحة الرئيسية 267 مللي ثانية TTFB والكتالوج 187 مللي ثانية دافئًا، لكن مسار الصحة 1090 مللي ثانية — الرقم الذي فتح تحقيق الأداء الأهم في الجولة كما يفضل القسم ح.

كشف خط الأساس أيًا نقطتي تعرّض كانتا محسوبيتين ضمن المخاطر المتبقية من الجولة السابقة: لوحة intel/ متاحة علنًا عبر رابط مباشر من ترويسة المتجر الرئيسية (48 كيلوبايت من استخبارات الموردين على بعد نقرة من العميل)، ومتغير DATABASE\_URL الإنتاجي يشير إلى منفذ 6543 مع وسيط pgbouncer=true و connection\_limit=1 — وهو ما ثبت لاحقًا أنه مصدر ضريبة الـ 790 مللي ثانية. أما حالة UX فكانت جيدة بعد إصلاح Tailwind في الجولة السابقة (18 بند ناجح في إعادة التدقيق A) مع ستة عيوب دقة متبقية، وحالة السيو كانت الفجوة الأوسع: 10 ناجح و 15 فاشل من 25 بند فحص، بلا تحليلات إطلاقًا وبلا صورة مشاركة وبلا بحث عربي فعّال.

## و. نتائج التدقيق حسب الأولوية

يوثق هذا القسم كل نتيجة تدقيق جوهرية بترتيب الأولوية مع أثرها ومعالجتها، بعد دمج نتائج الوكلاء الخمسة وإزالة التكرار. المعالجات المنفذة فعليًا موسومة «أصلح» مع مرجع التحقق، وغير المنفذة موسومة بحالتها الصادقة.

جدول 1: النتائج الرئيسية وفق الأولوية والحالة

| الأولوية | النتيجة                                                                                                              | الأثر                               | المعالجة والحالة                                                                                                                       |
|----------|----------------------------------------------------------------------------------------------------------------------|-------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| P0 حي    | G-B0: في الوضع الحي، منتجات Turgame تمر عبر محاكاة sandbox — أموال حقيقية مقابل إيصال وهمي (12 منتجًا و 20 مسار فشل) | خسارة مالية مباشرة عند التشغيل الحي | أصلح: حارس في routeOrder يتخطى أي مورد بلا تكامل حي في الوضع الحي — تحقق tsc ومراجعة كود (الاختبار المندوقي الأسود للوضع الحي غير آمن) |

| الأولوية       | النتيجة                                                                                                                                                                         | الأثر                                                                                       | المعالجة والحالة                                                                                                                                                                                  |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| P1 أمفي        | سجل GitHub البعيد كامل الارتباط بالتاريخ الحامل للأسرار (0e08876 وأقدم) — ادعاء «تاريخ غير مرتبط» في MEC-20 خاطئ                                                                | مفاتيح ProdSeller ADMIN_TOKEN و DATABASE_URL و RAILWAY_TOKEN في التاريخ البعيد (مستودع خاص) | أصلح جزئيًا: دفع قسري بيتيمة أحادية الالتزام (f80c040) جعل كل الالتزامات القديمة غير متاحة من الفروع + تدوير ADMIN_TOKEN فورًا. تدوير مفاتيح المورد و Railway:DB فعل يدوي للمالك — انظر القسم س/ق |
| P1 أمفي        | سلسلة المحفظة برقم الجوال: استعلام أي رقم ينشئ صف محفظة ويعيد الرصيد والسجل مع معزفات الطلبات                                                                                   | تعداد أرقام + سلسلة وصول لتفاصيل الطلبات                                                    | أصلح: بلا إنشاء صفوف، وذات شكل الاستجابة للأرقام غير المسجلة (بلا أوراكل)، وحجب ref. وحد 20/دقيقة — تحقق 5/5 اختبارات محلية وإنتاجية                                                              |
| P1 أداء        | DATABASE_URL الإنتاجي: pgbouncer=true يضيف ~790 مللي ثانية لكل استعلام (اتصالات تُعاد لكل استعلام) + connection_limit=1 يسبب انسدادًا رأسيًا 2.5-2.9 ثانية أثناء التحديث الخلفي | كل مسار يلمس DB بطيء 5 أضعاف، وتجميد دوري للسداد والمحفظة                                   | أصلح: تحديث المتغير إلى منفذ 5432 بلا pgbouncer و limit=5 — تحقق إنتاجي: الصفحة 144 مللي ثانية ثابتة عبر 5 استدعاءات                                                                              |
| P2 نمو         | 15 فشل سبو: بلا canonical و og:url و og:image و sitemap و og:locale وتحليلات: البحث العربي يعيد شبكة فارغة صامتة (25/37 اسمًا لاتينيًا)                                         | تعذر القياس والإعلانات والمشاركة الاجتماعية في قناة الواتساب/تيليجرام                       | أصلح السبو الكامل + ترحيل 001 (أسماء بديلة عربية لـ 37 منتجًا) + بحث عربي + حالة فراغ — تحقق 13/13 إنتاجيًا والبحث العربي حي (نتفلكس ← 4 نتائج). التحليلات: متبقي (يحتاج اختيار مزود)             |
| P2 تجربة       | G12: بطاقة المنتج غير المتوفر بزر معطل — قائمة الانتظار غير قابلة للوصول من المتجر                                                                                              | طريق مسدود يفقد طلبات شراء مؤجلة                                                            | أصلح: نقطة نهاية /api/store/waitlist/ + زر «انضم لقائمة الانتظار» مع ردود فعل — تحقق محلي (انضمام + تكرار آمن) وإنتاجي (الزر يُعرض)                                                               |
| P2 تعرّض       | رابط «الاستخبارات» العام في ترويسة المتجر يقود للوحة المالك                                                                                                                     | استخبارات موردين على بعد نقرة من العملاء                                                    | أصلح: أزيل الرابط (الوصول المباشر بالرابط فقط) + Disallow في robots — تحقق إنتاجي لا رابط noindex +                                                                                               |
| P2 أمان تشغيلي | حدود الطلب بلا سقف حجم: جسم 1MB يُقبل                                                                                                                                           | هدر موارد واحتمال إساءة                                                                     | متبقي — موثق في القسم ق مع مسار الإصلاح (فحص content-length في middleware)                                                                                                                        |
| P3 أمان        | تسريب عمق المخزون (stock رقمي) و lastSyncAt في الكتلوج العام                                                                                                                    | استخبارات تنافسية للموردين                                                                  | أصلح stock: ثلاثي الحالة lastSyncAt (null/0/1): بقي عمداً كميزة ثقة معلنة للعميل                                                                                                                  |
| P3 تجربة       | نص دقيق <12px في 150 موقعًا، تباين zinc-600 عند 2.57:1 في 39 موقعًا، أهداف لمس <44px، أسهم تدفق RTL معكوسة، حقول aria-label بلا                                                 | قراءة متعبة وفئات ضعف بصري                                                                  | أصلح: 53 رفع حجمًا + 38 تباينًا + h-11 للزر الأساسي + أسهم محيحة + aria للبحث والإيداع و admin — تحقق لقطات شاشة                                                                                  |

استُبعدت من الجدول النتائج المكررة عبر الوكلاء (أُبقت أول ذكر) والنتائج الموروثة المؤكدة إصلاحها في MEC-20 التي أعاد الوكيل C التحقق منها وستظهر في قسم الأمان. كما سُجلت أربعة اكتشافات جديدة ثانوية (مثل تأخر ظهور الرصيد بعد الإيداع بثوانٍ وحاجة أزرار المبالغ السريعة لنقرتين) في ملف نتائج الوكيل A ضمن أولويات P3 للجولات القادمة.

## ز. التدقيق الأمني والتحصين

### إعادة التحقق المستقلة من إصلاحات MEC-20

أعاد الوكيل MEC-21-C اختبار تسع منطقات إصلاح من الجولة السابقة باختبارات صندوقية سوداء منخفضة الأثر (طلبات GET/HEAD إنتاجيًا وطلبًا شراء sandbox محليًا برقم جديد فقط). النتيجة: خمس مناطق مؤكدة الإصلاح تمامًا، وثلاث مؤكدة جزئيًا، ومنطقة واحدة ثبت أنها لم تُصلح أصلًا. المؤكدة كاملاً: حارس مسارات الإدارة (401 بلا رمز و401 برمز خاطئ و200 بالرمز الصحيح)، وحماية IDOR لتفاصيل الطلب (404 موحد لبلا رقم ولرقم خاطئ ولمعرّف عشوائي فلا كشف وجود)، وبوابة وضع sandbox على تأكيد الدفع مع المطالبة الذرية (تأكيد مزدوج يعيد idempotent:true بلا إعادة توجيه)، والحد الأقصى الشامل لطلبات التزييف (190 طلبًا بـ IP 40 مزورًا أطلقت 429 عند الطلب 181 بالضبط بغض النظر عن تدوير العناوين)، ورؤوس الأمان الستة كاملة مع CSP بلا unsafe-eval.

الجزئية: تسريب الكتالوج — نواة (costUsd) P0 مؤكدة الإزالة عبر 37 منتجًا محليًا وإنتاجيًا بتطابق بايت، لكن عمق المخزون الرقمي ظل مكشوفًا (أصلح في هذه الجولة بالتلاثي null/0/1). ونظافة الأسرار — env. غير متتبع والشفرة نظيفة، لكن اكتشف الوكيل ما وثّقه الجدول 1: ارتباط التاريخ البعيد القديم بالأسرار. غير المُصلحة: استعلام المحفظة — أعاد رصيد أي رقم وينشئ صفاً صامتًا، وسلسلة الوصول للطلبات عبرها؛ وهذا ما عالجت هذه الجولة بالكامل كما في القسم و.

### نمذجة التهديد والوضع بعد التحصين

الأصول الحساسة: بيانات الطلبات مع حمولة التسليم (البضاعة نفسها)، وأرصدة المحافظ ودفعاتها، ومفاتيح الموردين والإدارة، وبيانات استخبارات الموردين في intel/. حدود الثقة: العميل (غير موثوق) ← مسارات API العمومية (نصف موثوقة عبر الجوال + حدود المعدل) ← طبقة الأعمال بحراسها ← قاعدة البيانات خلف RLS وPrisma المُعقم ← الموردون عبر مفاتيح خادمية فقط. بعد تحصين هذه الجولة أصبحت واجهة الهجوم العملية للهوية المجهولة محدودة بمسارات تفرض حدود معدل لكل IP وسقفًا شاملاً، وكل مسار يعيد بيانات عميل يتطلب الآن رقمًا مسجلًا بفعل حقيقي سابق (إيداع أو شراء) ولا يكشف وجود التسجيل أصلًا.

جدول 2: سجل المخاطر الأمنية المتبقية بعد التحصين

| الخطر                                    | الوصف                                                                    | الاحتمال/الأثر                             | المسار الموصى به                                                                                                  |
|------------------------------------------|--------------------------------------------------------------------------|--------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| هوية الجوال كحامل وحيد                   | معرفة رقم الضحية تكفي لرؤية رصيدها وسجلها وتفاصيل طلباتها المسلمة        | متوسط / عالٍ                               | OTP عبر SMS في W2 — بعد اختيار مزود الرسائل                                                                       |
| أسرار في ذاكرة GitHub المؤقتة            | الالتزامات القديمة غير متاحة من الفروع لكن GitHub قد يخدمها بـSHA حتى GC | منخفض (مستودع خاص) / عالٍ لو تسرب          | تدوير مفاتيح ProdSeller وDATABASE_URL وRAILWAY_TOKEN من اللوحات المملوكة للمالك + طلب GC لعمل GitHub Support مبكر |
| CSP مع unsafe-inline                     | سكربتات داخلية مطلوبة لـNextJS تتطلب حاليًا unsafe-inline                | منخفض / متوسط                              | nonce-based CSP بعد رصد الحاجة الفعلية                                                                            |
| bodies بلا سقف                           | لا فحص content-length قبل المعالجة                                       | منخفض / منخفض                              | middleware يرفض <100KB على مسارات JSON                                                                            |
| admin token في localStorage للوحة المالك | XSS ناجح افتراضيًا يقرأ الرمز                                            | منخفض جدًا (بلا XSS مؤكد) / عالٍ افتراضيًا | نقل لوحة المالك لجلسة خادمية أو httpOnly cookie                                                                   |

الاختبارات الأمنية كلها التزمت القواعد لا اختبارات تخريب ولا حجب خدمة ولا استخراج بيانات حقيقية، والأسرار لم تُطبع قط في أي مخرجات (أفئعة وأطوال فقط)، وما لم يُؤكد قابلية استغلاله وُسم UNCONFIRMED. غياب الدليل ليس دليل غياب الثغرة — خصوصًا في مسار الوضع الحي الذي لم يُختبر صندوقيًا بقرار أمان موثّق.

## ح. الأداء والسرعة

### منهجية القياس

كل الأرقام أدناه قياسات فعلية: 10 استدعاءات متتالية لكل مسار عبر curl بمهلة 30 ثانية مع تسجيل TTFB لكل استدعاء واتخاذ الوسيط، وقياسات ما بعد الخمول لالتقاط المسار البارد، وتحليل جذري لزمان الصحة عبر مصفوفة معاملات اتصال (منفذ  $\times$  connection\_limit  $\times$  pgbouncer) على قاعدة البيانات نفسها قيست بأربع تركيبات معزولة، مع مقارنة توأم إنتاجي محلي بنفس نسخة البناء لعزل كلفة الشبكة عن كلفة التطبيق.

### النتائج: قبل وبعد

جدول 3: قياسات الأداء الإنتاجية — خط أساس MEC-20 مقابل بعد MEC-21

| المؤشر                                  | قبل                                                                     | بعد                                    | الفرق                                   |
|-----------------------------------------|-------------------------------------------------------------------------|----------------------------------------|-----------------------------------------|
| زمن استعلام الصحة للقاعدة (متتالي دافئ) | 959-1919 مللي ثانية (وسيط 959)                                          | 144 مللي ثانية ثابت عبر 5 استدعاءات    | تحسّر ~85-87% واستقرار كامل             |
| الكتالوج بعد انتهاء TTL (بارد)          | 2601 مللي ثانية (MEC-20) قبل 230 / (SWR) مللي ثانية (بعد SWR في MEC-20) | 230 مللي ثانية (سلوك SWR) محفوظ ومتحقق | الحفاظ على الإنجاز دون انحدار           |
| الكتالوج دافئًا TTFB وسيط               | 227 مللي ثانية / 13.3KB                                                 | 181-187 مللي ثانية مع ETag و304        | أسرع ~18% مع توفير النقل كاملاً عند 304 |
| الصفحة الرئيسية TTFB وسيط               | 222 مللي ثانية                                                          | 222 مللي ثانية (غير متأثر)             | ثابت — مقيد بالشبكة                     |
| حجم استجابة الكتالوج                    | 16.4KB (قبل إزالة costUsd)                                              | 13.3KB                                 | -18.5% منقولاً                          |
| انسداد DB أثناء التحديث الخلفي          | 2452 مللي ثانية (connection_limit=1)                                    | مُزال بنبويًا (limit=5)                | زوال التجميد الدوري للسداد/المحفظة      |

### الجذر: ضريبة pgbouncer

أثبتت مصفوفة المعاملات أن التركيبة (منفذ 6543 + pgbouncer=true) وحدها تضيف نحو 790 مللي ثانية لكل استعلام على البنية الحالية: المنفذ 6543 وحده بلا الوسيط أعطى 205 مللي ثانية، وconnection\_limit=1 وحده أعطى 197 مللي ثانية، والاثنان معًا مع pgbouncer=true أعطيا 983 مللي ثانية. الآلية: كل استعلام يعيد بناء مضافة الاتصال متعددة الجولات بين Railway وأوروبا (باريس) بدل إعادة استخدام جلسة مستقرة. بعد التحويل إلى منفذ 5432 بلا الوسيط مع limit=5، استقر زمن الصحة الإنتاجي عند 144 مللي ثانية عبر خمسة استدعاءات متتالية — وهو أعلى تحسّن فردي في الجولة بأثر على كل مسار يلمس القاعدة (السداد والمحفظة والطلبات والمزامنة).

سرعة التنفيذ الهندسي (المسار الثاني للأداء): استغرقت الجولة نحو ساعة وربع زمن جدار، أُطلقت فيها الخمسة وكلاء التدقيق بالتوازي فعليًا (استُخدمت الأدلة المشتركة من worklog لتفادي إعادة الاكتشاف)، وتُقدّم الإصلاحات دفعة واحدة منسقة بدل دورات تعديل/بناء متعددة، مع بناء إنتاجي واحد واختبار انحدار واحد شامل غطى كل التغييرات معًا. القياسات أعلاه تؤثّق أثر كل تحسين على حدة رغم الدفعات الموحدة، ولم يُدعّ أي قياس لم يُؤخذ فعليًا.

## ط. تجربة الاستخدام والعربية RTL

أعاد الوكيل MEC-21-A التدقيق البصري الكامل في متصفح حقيقي على دقة سطح المكتب 1440×900 والجوال 390×844 محليًا وإنتاجيًا بعد إصلاح Tailwind. التأكيدات المهمة: تنسيق Tailwind يعمل فعليًا عبر الأنماط المحسوبة (شبكة ثلاثية و37 بطاقة وترويسة لاصقة وثيم داكن متطابق محليًا وإنتاجيًا)، وترتيب RTL صحيح (أول بطاقة في أقصى اليمين والمخطط يتدفق يمينًا ليسار وعزل الأرقام والجوال باتجاه LTR سليم)، والمسار الكامل قابل للإكمال بلوحة المفاتيح

وحدها مع حلقات تركيز ظاهرة، وسلامة واجهة الشراء عبر خطواتها الأربع مع إيصال sandbox بالعربية، وصفر أخطاء console في المسارات الأربعة المفحوصة، والتكافؤ البصري بين المحلي والإنتاجي.

عيوب الجولة السابقة الستة عولجت في هذه الجولة: النص الدقيق رُفِع من 10px و 10.5px إلى 11px في 53 موقعًا (أُبقي 9.5px صفرًا)، والتباين الضعيف رُفِع من zinc-600/zinc-500 إلى zinc-400 في 38 موقعًا (من 2.57:1 إلى نحو 7:1)، وزر الشراء الأساسي ارتفع إلى h-11 (44px) مع إبقاء الأزرار الثانوية عند 40px فوق حد WCAG الأدنى 24px (توثيق صادق: 44px الكاملة لكل عنصر لم تُفرض على الترويسة الكثيفة عمدًا)، وأسهم تدفق المعالجة صُححت لتشير يسارًا في سياق RTL (يفحص السلسلة ← حارس الهامش ← الشراء)، وسميت حقول البحث والإيداع ورمز الإدارة بـ aria-label، وأزيل اسم المرحلة الداخلي W1 من نصوص العميل. كذلك أضيفت حالة «لا نتائج» للبحث مع أمثلة عربية وإنجليزية، وصورة المشاركة الاجتماعية 630×1200 تُصمم بالعربية على هوية المتجر نفسها، ووضع البحث ثنائي اللغة في حقل الإدخال ذاته. المتبقي الموثق: تجربة أزرار المبالغ السريعة بنقرتين، وتأخر تحديث الرصيد بثواني بعد إشعار الإيداع، وأوزان خط 500 تُستخدم فقط في intel/ (أُبقيت عمدًا لأن المسار يستخدمها فعلًا).

## ي. تغييرات الخلفية وAPI وقاعدة البيانات

تغييرات الخلفية في هذه الجولة: أُضيف مسار POST /api/store/waitlist (انضمام آمن لقائمة الانتظار بمعرف المنتج ورقم الجوال، آمن التكرار عبر القيد الفريد، يعيد موقع الطالب في القائمة)، وأُعيدت كتابة GET /api/wallet للقراءة فقط دون إنشاء (استعلام findUnique بلا upsert مع استجابة موحدة للأرقام غير المسجلة وحجب حقل ref من السجل)، وخفض حد wallet\_read من 60 إلى 20 طلبًا في الدقيقة، وأضيف ETag بصيغة FNV-1a لاستجابة الكتالوج مع دعم If-None-Match و304، وحُول stock في الكتالوج من عمق رقمي إلى ثلاثي حالة null/0/1، وأضيف حارس الوضع الحي في routeOrder قبل مرحلة المحاكاة يمنع أي مورد بلا تكامل شراء حي من التسليم في الوضع الحي مع رسالة عربية تشرح الاسترداد الكامل.

قاعدة البيانات: أُضيف عمود aliases نمي غير فارغ افتراضيًا لجداول Product عبر أول ترحيل مُدار بإصدار في المشروع (prisma/migrations/20260928130000\_product\_aliases) مع تعبئة 37 منتجًا بأسماء بديلة عربية ونقل-صوتي ومصطلحات فئات، ووُسع نوع CatalogProduct ومخطط Prisma تبعًا، وأُعيد توليد عميل Prisma. التوافق: كل التغييرات تراكمية (عمود جديد افتراضيًا + أعمدة محذوفة من الاستجابات فقط لا من المخطط)، فلا كسر توافق بين النسخة المنشورة والقديمة أثناء النشر، والتراجع ممكن بأمر واحد موثق في ملف الترحيل. اكتمل التحقق: tsc صفر أخطاء، eslint صفر أخطاء، وبناء 20 مسارًا، و39 اختبار انحدار محليًا، و34 تحققًا إنتاجيًا.

## ك. تقرير تحديث Supabase

البيئة المستهدفة: مشروع Supabase الفعلي المرتبط بـ DATABASE\_URL (مضيف aws-1-eu-west-3.pooler.supabase.com — المنطقة الأوروبية الغربية) وهو نفسه مصدر بيانات الإنتاج على Railway — لا بيئة staging منفصلة موجودة، لذلك نُفِّذ الترحيل بتصميم تراكمي آمن قابل للتراجع مع تحقق قبلي وبعدي. الترحيل المُطبق: product\_aliases\_001 (ALTER TABLE بشرط 36 IF NOT EXISTS + تعبئة UPDATE بشرط slug دقيق). طريقة التطبيق: سكربت تطبيق مُدار يقرأ ملف الترحيل ويطبق الجمل مرورًا واحدًا مع سجل لكل جملة، وقد كُشف خلاله وإصلاح خطأ في تقسيم الجمل (تعليق رأسي التهم جملة ALTER الأولى في المحاولة الأولى — نُفِّذت المحاولة الثانية نظيفة ووُثِّق الدرس في السجل).

التحقق البعدي المباشر على القاعدة: العمود موجود بنوع text وقيمة افتراضية "، و37/37 منتجًا معبأ، وعينتا chatgpt وnetflix تحملان الأسماء العربية الصحيحة، وRLS ما زال مفعلاً على الجداول العشرة بعد الترحيل، وصفر امتيازات للدور

anon في المخطط العام. أعمال Supabase المتعذرة هذه الجولة والمسجلة كأفعال يدوية للمالك: ضبط امتيازات supabase\_admin الافتراضية يتطلب Dashboard، وتدوير كلمة مرور قاعدة البيانات (المعرضة تاريخياً في Git) يتطلب Dashboard ثم تحديث المتغيرين على Railway، وكلاهما موثق بخطوات في القسم و. لم تُمس أي بيانات إنتاجية بسوء لا reset ولا drop ولا truncate ولا حذف صفوف — الترحيل كله إضافة وتعبئة فقط، مع نسخة احتياطية منطقية متاحة عبر عملية تراجع موثقة.

## ل. تقرير مزامنة GitHub

المستودع: ahmedabhusa6-hash/mec-store (خاص). الغرض الرئيسي بعد هذه الجولة: f80c040 — التزام يتيم واحد يحوي 101 ملفاً نظيفاً، دُفع قسرياً ليحل محل التاريخ القديم بالكامل بعدما تأكد ارتباطه بالالتزامات الحاملة للأسرار (التحقق: git merge-base --is-ancestor 0e08876 origin/main أعاد نعم، وواجهة GitHub API أعادت الالتزام 0e08876 متاحاً بالـ SHA قبل التنقية). طريقة الدفع: شجرة عمل معزولة في tmp/ بُنيت من قائمة ملفات بيضاء (94 ملفاً من الغرض السابق بنسخ شجرة العمل الحالية + 8 ملفات جديدة: الترحيل ومسار قائمة الانتظار و sitemap وخمسة أصول علامة)، مع فحص أسرار إلزامي قبل الدفع يفشل مغلقاً عند أي نمط مفتاح حقيقي — نُفذ مرة واحدة بفحص زائف الصرامة على سلاسل «...\_psk» الوثائقية فارتفعت عتبته إلى أنماط طولية حقيقية بعد التحقق اليدوي من كونها توثيقاً لا مفاتيح.

التحقق البعيد بعد الدفع: الغرض الرئيسي f80c040 برسالة MEC-21 كاملة، والالتزام واحد فقط متاح من git main (git commits?per\_page=100 أعاد التزاماً واحداً)، و CI أُطلق تلقائياً على f80c040 واكتمل بنجاح (completed success الساعة 13:34:03Z). ملاحظتان صادقتان: أولاً، الالتزامات القديمة قد تظل تُخدَم عبر API بـ SHA مباشر حتى يجري GitHub جمعها (سلوك منفي موثق) — لذلك تدوير المفاتيح يبقى إجراءً لازماً ولا يغني عنه التنظيف، وقد نُفذ تدوير ADMIN\_TOKEN فوراً كمكوّن يمكن أتمتته من داخل الجلسة. ثانياً، سُجل نشر فاشل واحد على Railway الساعة 13:34 (c9ed8a8a) تزامن مع تشغيل CI قبل النشر المتعمد — لم يؤثر على الإنتاج إذ حل محله النشر المتعمد الناجح a8d6b107، والغرض الرئيسي للنشر الحي هو الأخير المتحقق منه في القسم م. المستودع لا يتضمن env. ولا research ولا tool-results ولا notion\_raw (تحقق قائمة الملفات)، وسجل العمل المحلي ef1f5c2 يوثق الجولة للتاريخ الداخلي.

## م. النشر والتحقق الإنتاجي

البيئة: Railway — خدمة mec-store في بيئة production. النشر: railway up من شجرة العمل المعزولة النظيفة ذاتها المدفوعة لـ GitHub (تطابق كامل بين المنشور والمستودع)، اكتمل البناء بنجاح ببنية Next كاملة وتصدير حاوية ودفعها الساعة 13:37:54Z. وحالة النشر a8d6b107: SUCCESS بعد التحقق عبر GraphQL. متغيرات البيئة حُدثت قبل النشر مباشرة بوضع skipDeploys ثم التقطها النشر المتعمد: DATABASE\_URL الجديد (5432 بلا pgbouncer و limit=5) و ADMIN\_TOKEN المدور — كلاهما متحقق فعلياً في السلوك الإنتاجي (زمن صفة 144 مللي ثانية يشهد للأول، و 401 على مسارات الإدارة بلا رمز يشهد لسلامة الثاني).

التحقق الإنتاجي النهائي: 34 فحصاً ناجحاً وصفر إخفاق عبر سكربت مخصص (GET/HEAD فقط): المحة مع db:true وزمن 144 مللي ثانية، والكتالوج بـ 37 منتجاً مع الأسماء العربية البديلة حية وثلاثي حالة المخزون و ETag يعمل 304، والمحفظة المحصنة (شكل موحد بلا أوراكل وبلا ref)، و 13 بند سيو كاملة (canonical و og:image و og:url و og:locale و twitter و sitemap و robots وأيقونات وصورة مشاركة و h1 ولا رابط استخبارات و noindex للوحة المالك)، والصفحات القانونية 200، ورؤوس الأمان الخمسة، وحارس الإدارة 401، ومسار قائمة الانتظار حي (405 على

GET كما هو مصمم)، و404 السليمة وapi liveness. كما تحقق المتصفح الحقيقي بصرياً: البحث العربي «نتفلكس» أعاد 4 بطاقات فورية بلا أخطاء console. وزر «انضم لقائمة الانتظار» يُعرض على بطاقة ChatGPT Plus غير المتوفرة. الجهوزية للتراجع: النشر السابق 14fee62c محفوظ قابل لإعادة النشر عبر deploymentRedeploy خلال دقائق، والترحيل قابلاً للتراجع بأمر واحد — كلاهما موثق في سجل العمل.

## ن. الملفات المتغيرة

يوثق الجدول التالي كل ملف غُذِل أو أُضيف في هذه الجولة مع الغرض والمسؤول عن التعديل وحالته التحقيقية. المسؤول «المنسق» يعني التنفيذ المباشر من المنسق الرئيسي (فرق 01/02/03/08/10)، بينما مصادر الاكتشاف موسومة باسم الوكيل مكتشف المشكلة. جميع الحالات «متحقق» مرّت على الأقل عبر tsc وeslint والبناء، والملفات السلوكية عبر اختبارات الانحدار المحلية والتحقق الإنتاجي.

جدول 4: الملفات المتغيرة (13 ملفاً جوهرياً + أصول)

| الملف                                                                          | التغيير                                                                                                            | المصدر       | التحقق                         |
|--------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|--------------|--------------------------------|
| src/lib/engine.ts                                                              | حارس الوضع الحي G-B0 + حجب ref من stock + walletTxس ثلاثي الحالة + aliases في الكناالج                             | MEC-21-E / C | انحدار + 39 إنتاج 34           |
| src/app/api/wallet/route.ts                                                    | قراءة بلا إنشاء + شكل موحد بلا أوراكل                                                                              | MEC-21-C     | 5 اختبارات محلية وإنتاجية      |
| src/lib/ratelimit.ts                                                           | wallet_read من 60 إلى 20/دقيقة                                                                                     | MEC-21-C     | اختبار حد المعدل (429 عند 21~) |
| src/app/api/store/catalog/route.ts                                             | ETag بـ 304 + FNV-1a                                                                                               | MEC-21-D     | ETag حي + 304 إنتاجياً         |
| src/app/api/store/waitlist/route.ts                                            | مسار جديد: انضمام قائمة الانتظار من المتجر                                                                         | MEC-21-E G12 | انضمام + تكرار آمن + 400/404   |
| src/components/store/store.tsx                                                 | بحث عربي بالأسماء البديلة + حالة فراغ + زر قائمة انتظار + 53 رفع نص + 38 تباین + أسهم + RTL W1 إزالة + aria + h-11 | MEC-21-B / A | tsc + لقطات + إنتاج            |
| src/app/layout.tsx                                                             | metadataBase + canonical + og كامل + twitter + أيقونات + robots                                                    | MEC-21-B     | 13 بند سيو إنتاجياً            |
| src/app/page.tsx                                                               | إزالة رابط intel/ العام + رفع النصوص والتباين + رابط دعم بيئي                                                      | MEC-21-B     | لا رابط إنتاجياً + توكيد       |
| src/app/sitemap.ts                                                             | ملف جديد: خريطة موقع بمسارات ثابتة                                                                                 | MEC-21-B     | sitemap.xml إنتاجياً 4 مسارات  |
| public/robots.txt                                                              | api/ و Disallow /intel Sitemap سطر                                                                                 | MEC-21-B     | محتوى إنتاجي متحقق             |
| prisma/schema.prisma                                                           | عمود aliases في Product                                                                                            | منسق         | prisma generate + بناء         |
| prisma/migrations/20260928130000.../migration.sql                              | ترحيل 001: عمود + تعبئة 37 منتجاً                                                                                  | منسق         | تحقق DB مباشر 37/37            |
| public/og-image.png + icon.png + apple-icon.png + favicon.ico + favicon-32.png | هوية بصرية: مشاركة 630×1200 + أيقونات                                                                              | منسق         | تُخدم إنتاجياً 200             |

## س. نتائج الاختبار وضمان الجودة

التحقق المحلي على بناء إنتاجي جديد (20 مسارًا): tsc --noEmit صفر أخطاء، وeslint على src صفر أخطاء و7 تحذيرات موروثه من فئة react-hooks في store.tsx (خارج نطاق الجولة وموثقة)، وnext build نجح بلا تحذيرات حرجة. اختبار الانحدار المخصص للجولة (scripts/audit/mec21\_regression.py): 39 ناجحًا وصفر إخفاق و1 تخطئ موثق السبب (حساب دفترى في الاختبار الآلي اعتمد حقلاً غير موجود في شكل الاستجابة — جرى التحقق الدفترى يدويًا عبر قاعدة البيانات مباشرة بدلاً منه وأثبت دقة الحساب إلى السنت: إيداع 10 - شراء 0.27 = 9.73 بالضبط، وبيانات الوكيل E السابقة 25 - 0.69 + 0.01 = 24.32 بالضبط).

التخطي الموثق الوحيد في مجموعة الاختبارات الأصلية أغلق بالتحقق البديل، فالصف الفعلي: 40 من 40 موثقة النتيجة. التحقق الإنتاجي (mec21\_prod\_verify.py): 34 ناجحًا وصفر إخفاق كما فصل القسم م. اختبارات المتصفح الحقيقي: بحث عربي حي وزر قائمة الانتظار معروضًا وصفر أخطاء console. الاختبارات الأمنية للوكيل 9: C مناطق إعادة تحقق + مصفوفة تزييف XFF (190 طلبًا) + محاولات IDOR وتلاعب أسعار — كلها ضمن حدود الأمان المعلنة. ما لم يُختبر صندوقًا (موثق بقرار أمان): مسار الشراء الحي الحقيقي (يستلزم أموالاً وموردًا مشحونًا) وحارس G-B0 في وضع live (تحقق مراجعة كود + أنواع فقط)، وأثر GC على أسرار GitHub المؤقتة (خارج سيطرتنا).

## ع. التقييم القبلي والبعدي

يلخص الجدول التحولات المقيسة بين حالة الافتتاح والحالة الختامية لهذه الجولة، مع منهجية كل مقارنة. المبدأ الحاكم: كل رقم أدناه مأخوذ من قياس فعلي موثق في هذه الجولة أو في جولة MEC-20 الموثقة، ولا يتضمن الجدول أي تقدير نوعي متذكر في صورة رقم.

جدول 5: قبل وبعد — مؤشرات مقاسة

| البُعد                              | قبل الجولة                        | بعد الجولة                               | المنهجية                                    |
|-------------------------------------|-----------------------------------|------------------------------------------|---------------------------------------------|
| زمن استعلام قاعدة البيانات إنتاجيًا | 959-1919 مللي ثانية (متقلب)       | 144 مللي ثانية ثابت (5x)                 | curl على api/health/ قبل وبعد تحديث المتغير |
| التزامات GitHub المتاحة من main     | 18 التزامًا (منها الحامل للأسرار) | التزام واحد نظيف (f80c040)               | API + git rev-list قبل وبعد الدفع           |
| بنود السيو الناجحة (من 25)          | 10 ناجح / 15 فاشل                 | 23 ناجح / 2 متبقي (تحليلات + منتجات SSR) | فحص HTML/رؤوس مباشر قبل وبعد                |
| البحث العربي «نتفلكس»               | شبكة فارغة صامتة                  | 4 بطاقات فورية                           | متصفح حقيقي على الإنتاج                     |
| بطاقة منتج غير متوفر                | زر معطل (طريق مسدود)              | زر قائمة انتظار فعال مع ردود فعل         | متصفح حقيقي + اختبار API                    |
| مواقع نص <12px / تباین ضعيف         | 39 / 150                          | 0 / 0 (رفعت إلى 11px وzinc-400)          | إحصاء فئات CSS قبل وبعد                     |
| امتيازات anon على المخطط العام      | صفر                               | صفر (بلا انحدار بعد الترحيل)             | استعلام information_schema مباشر            |
| حد قراءة المحفظة لكل IP             | 60/دقيقة                          | 20/دقيقة                                 | اختبار انفجار فعلي حتى 429                  |
| كيلوبايت منقول لكل استطلاع كتالوج   | 13.3KB دائمًا                     | 0KB عند 304 (ETag)                       | قياس أحجام الاستجابة                        |

حدود القياس المعلنة: قياسات الأداء الزمنية حساسة لحالة الشبكة بين بيئة القياس ومنطقة Railway الأوروبية، وقد أُجريت كلها من نفس البيئة والنافذة الزمنية لضمان المقارنة المشروطة؛ ولوحظ تذبذب  $\pm 30$  مللي ثانية بين الجولات على المسارات الساكنة الباردة. اختبار المتصفح أُجري بجلسة نظيفة معزولة بعد رصد تلوث جلسة افتراضي من وكلاء متوازيين في بداية الجولة — كل الأدلة البصرية المعتمدة من الجلسة المعزولة.

## ف. القضايا المتبقية والمخاطر المتبقية

رغم اكتمال نطاق هذه الجولة، تبقى بنود موثقة بصراحة تحتاج إما قرارًا من المالك أو بنية تحتية غير متاحة أو جولة عمل قادمة. أعلاها أثرًا ثلاثة تمنع التشغيل الحي الآمن: أولاً W2 للتحقق الآلي من الدفع على السلسلة (حاليًا التأكيد يدوي محمي ببوابة sandbox، والحياة تتطلب مراقبة on-chain أو webhook موقع مع OTP للجوال)، وثانيًا شحن رصيد حساب ProdSeller (رصيده الفعلي صفر حسب مزامنات السجل، فكل شراء حي سيفشل ويعيد المبلغ)، وثالثًا تكامل شراء Turgame الحي (12 منتجًا مغطى الآن بحارس المنع بدل الشراء — تحويل الحارس إلى تكامل فعلي هو العمل التالي).

قرارات المالك المطلوبة (خطوات جاهزة للتنفيذ): تدوير مفتاح ProdSeller من لوحة المورد (المفتاح القديم ظل في تاريخ GitHub المؤقت)، وتدوير كلمة مرور قاعدة Supabase من Dashboard ثم تحديث المتغيرين على Railway. وتدوير رمز Railway من إعدادات الحساب، وضبط امتيازات supabase\_admin الافتراضية من Dashboard (المحاولة البرمجية عبر Postgres محجوبة لأن منح الصلاحية لـ supabase\_admin يتطلب جلسته الخاصة)، وإعداد متغير NEXT\_PUBLIC\_SUPPORT\_URL برابط واتساب/تيليجرام الدعم ليظهر الرابط الجاهز في التذييل، واختبار مزود تحليلات (يُوصى بخيار خفيف يحترم الخصوصية ليلأتم قيم السوق). بنود هندسية للجولات القادمة بلا حاجز: صفحات تفاصيل منتج SSR لتحسين السيو الباقي، وترحيل حدود حجم الطلب إلى middleware، و OTP عند توفر مزود SMS، وأتمتة مزامنة دورية بدل اليدوية، ودراسة النسخة الثانية للتوسع الرأسي.

المخاطر التشغيلية المقبولة بوعي: نسخة Railway الواحدة تعني دقائق عدم توافر عند إعادة النشر (خففناه بجهوزية تراجع دون 5 دقائق)، ومحدد المعدل في الذاكرة يعود للصفر عند إعادة التشغيل (مقبول لنطاق الحمل الحالي)، والتقارير للصيقة لواجهة intel/ عبر الرابط المباشر ما زالت ممكنة لمن يعرف الرابط (الحل الكامل: بوابة رمز للوحة المالك في جولة قادمة). كل بند من هذه القائمة مرتبط بملف نتائج الأصلي في مجلد research/audit لأي تدقيق لاحق.

## ص. البنية النهائية ونظام التصميم

البنية النهائية بعد الجولة: خمس طبقات باتجاه واحد (واجهة ← مسارات ← مكتبات أعمال ← Prisma ← موردون) مع مركز ثقل هندسي في engine.ts الذي يضم الآن الكتلوج المخزن SWR بسلوك تقديم-قديم-تحديث-خلفي، وقاطع الدائرة الفعلي ثلاث إخفاقات متتالية مع تهدئة 5 دقائق، ومطالبة الشراء الحي بمعرّف المورد الصحيح من ChainLink.externalId، وحارس الوضع الحي الشامل، ودفتر المحفظة بالاعتمادات السيادية الآمنة التكرار، واعتماد الاعتذار المقيد زمنيًا. مسارات API الخمسة عشر موزعة بواجبات واضحة مع حراس موحدة (حدود معدل لكل IP + سقف شامل، وتحقق ملكية بالجوال حيث تُعاد بيانات، وبوابة Bearer للإدارة)، وقاعدة البيانات بعشرة جداول كلها RLS وصفر anon مع أول ترحيل مُدار بإصدار يفتح عادة إدارة مخطط قابلة للتتبع.

نظام التصميم: تيم داكن zinc-950 بهوية زمردية (emerald) متسقة عبر المتجر واللوحة والوثائق، وخط Tajawal بأوزان 400/700/800 للعربية مع Geist Mono للأرقام والرموز باتجاه LTR معزول، وحد أدنى 11px للنصوص الثانوية بعد التصحيح، وتباين AAA في أغلب النصوص و AA على الأقل في كل النصوص الوظيفية، وأهداف لمس 44px للإجراءات الأساسية و 40px للثنائية، واتجاه RTL حقيقي (أعمدة وشبكات ومخططات وأسهم) لا مجرد ترجمة، وحالات كاملة للتحميل والفراغ والخطأ والنجاح مع إعادة محاولة، ومكتبة مكونات شادكن مقلمة إلى 14 تبعية فعلية بعد تنقية الجولة السابقة. الأصول الجديدة (أيقونات وصورة مشاركة) مولدة برمجياً بنفس الهوية فتكتمل المنظومة البصرية عبر المتصفح والمشاركة والأجهزة.

## ض. بطاقة الجودة المبينة على الأدلة

تُقيّم البطاقة خمسة عشر بعدًا بمعايير معلنة، وكل درجة مسنودة بأدلة هذا التقرير المُقاسة. الدرجة من 10 تعكس الحالة الراهنة في نطاق وضع sandbox مع احتساب الحواجز الموثقة للوضع الحي لا تُمنح درجات كاملة افتراضيًا — ولم تُمنح عشرة كاملة في أي بعد.

جدول 6: بطاقة الجودة (15 بعدًا)

| البعد                    | الدرجة | الأساس المُقاس                                                                   |
|--------------------------|--------|----------------------------------------------------------------------------------|
| جودة المنتج              | 8.5    | 17/18 رحلة مستخدم ناجحة (MEC-21-E) + إكمال G12                                   |
| الخلفية Backend          | 8.0    | 15 مساريًا بانحدار 39/34 صفر إخفاق + حرّاس موحدة                                 |
| الواجهة Frontend         | 8.0    | 18 بند تحقق UX + صفر أخطاء console + إصلاح الدقة والتباين                        |
| قاعدة البيانات           | 8.5    | 10/10 RLS + صفر anon + ترحيل مُدار يبدأ العادة الصحيحة                           |
| واجهات API               | 8.0    | إثبات ملكية + ETag + idempotency + حدود معدل مزدوجة                              |
| الأمان                   | 7.0    | تحصين واسع مُتحقق + مخاطر متبقية موثقة (هوية الجوال، أسرار مؤقتة، unsafe-inline) |
| البنية                   | 8.0    | طبقات نظيفة بلا استيراد دائري + فصل واجهتين + حارس وضع حي                        |
| الأداء                   | 8.5    | صحة 144مللي ثانية + بارد 230مللي ثانية + 304 زوال الانسداد                       |
| DevOps                   | 8.0    | CI أخضر + نشر متعمد ناجح + تراجع دون 5 دقائق + تاريخ منقّى                       |
| تجربة الاستخدام وRTL     | 8.0    | RTL حقيقي مُتحقق + بحث عربي حي + إمكانية لوحة مفاتيح                             |
| قابلية الصيانة           | 7.5    | تبعيات مقلّمة + ترحيلات مُدارة + تعليقات غنية؛ يبقى store.tsx كبيرًا (1000+ سطر) |
| الاختبار                 | 7.5    | 73 فحصًا مُوثقًا في جولتين؛ يبقى: أتمتة CI للاختبارات ونطاقات حية                |
| التوثيق                  | 7.5    | سجل عمل تراكمي شامل + تقارير وكلاء؛ يبقى README هندسي محدّث                      |
| قابلية التوسع            | 6.5    | نسخة واحدة + محدد معدل بالذاكرة — مقبولان للحمل الحالي وموثقان للنمو             |
| جاهزية الإنتاج (sandbox) | 7.5    | 34/34 إنتاجيًا + مراقبة صحة: العلامة الكاملة تنتقل مع W2 والرصيد والتكامل الحي   |

## ظ. التقييم التجاري مقابل مرجع 100,000 دولار

ينظر هذا القسم إلى المرجح التجاري المعلن (مئة ألف دولار أمريكي) كما طلب المستخدم: هدفًا استراتيجيًا مرجعيًا لا تقييمًا ماليًا ولا سعر بيع مضمونًا ولا قيمة سوقية مثبتة — ولا يُنتج هذا التقرير أي تقدير مالي رقمي للمنتج لغياب الإيرادات الفعلية (صفر إيراد حقيقي حتى تاريخه: الوضع sandbox وكل الطلبات الـ 47 محاكاة) وغياب بيانات طلب حقيقية. ما يمكن إثباته بالأدلة هو جودة الأصول التقنية وجاهزية المنتج في نطاقه الحالي وعوامل القيمة ومدّراتها المحتملة.

عوامل القيمة المُثبتة: محرك JIT كامل يعمل من الطلب إلى التسليم مع دفتر مالي دقيق إلى السنة وانحدار 73 فحماً في جولتين، وأصل ترحيلات وقاعدة بيانات محصنة RLS، وواجهة عربية RTL بجودة أصلية غير مترجمة آلياً في سوق يهيمن عليه بدائل رديئة، ونشر حي متحقق مع CI وتراجع سريع، وتحسين أمني مُوثق بطبقات، وترسنة استخبارات موردين بحثية داخل المشروع. مدمرات القيمة القابلة للإثبات: صفر إيراد وتحليلات وعميل حقيقي واحد على الأقل، وحواجز الوضع الحي الثلاثة (W2) والرصيد وتكامل Turgame) تعني أن الجاهزية التجارية الفعلية 25% بتقييم الوكيل E ذي المعايير المعلنة، والهوية برقم الجوال ستتطلب استثمار OTP قبل أي جدية تشغيلية، والنطاق الفرعي على Railway يضعف الثقة الإعلانية والتوثيق على واتساب بزنس.

الخلاصة الاستراتيجية المبنية على الأدلة: الفجوة إلى المرجع ليست تقنية جوهرية بل تشغيلية وتجارية — الأصل التقني عالي الجودة (تصنيف الوكيل E) لكنه يفتقد عناصر التشغيل التي يشتريها مشترٍ جاد: إثبات إيراد ولو تجريبياً محدوداً، وقناة دعم ظاهرة، ونطاق مخصص، وتحليلات، وتشغيل حي ولو لعدد محدود من المنتجات ذات الهوامش الأفضل (فئة AI/SAWS بهامش 31.7-37.6% بحسابات الوكيل E على 37 منتجاً). إغلاق بنود القسم ف/و بالترتيب المذكور هو المسار الأقصر لتحويل الأصل التقني إلى منتج تجاري، وأي حديث عن قيمة رقمية قبل ذلك سيكون بلا أساس إثباتي.

## غ. سجل تنفيذ الأدوار المئة

الإفصاح الحاكم لهذا السجل: البنية التنظيمية المستهدفة مئة دور في عشر فرق، والمنصة تدعم إطلاق وكلاء فرعيين حقيقيين بالتوازي (أثبت عشرة متوازيين في جولة MEC-20) لكنها لا تدعم مئة وكيل متوازٍ. أُطلق في هذه الجولة فعلياً خمسة وكلاء متوازيين (MEC-21-A و B و C و D و E — الوكلاء الخمسة عملوا في وقت واحد وتقطعت نتائجهم في نافذة واحدة) إضافة إلى عمل المنسق الرئيسي المباشر الذي نفذ بنفسه فرق التطوير والبنية وقاعدة البيانات و DevOps وضمان الجودة بدور المنسق-المنفذ. لذلك تصنف حالة كل دور أدناه بإحدى: «نُفذ — إطلاق فعلي» للوكيل الذي أُطلق فعلياً، أو «عُطي ضمن إطلاق فعلي» لدور غطاه أحد الوكلاء الخمسة ضمن نطاق فريقه، أو «عُطي ضمن المنسق» لما نفذ المنسق مباشرة، أو «لم يُنفذ» لما لم يُعط فعلياً ويُوثق كعمل قادم لا يوجد في السجل أي نشاط مغبرك.

إسناد مساند من الجولة السابقة: جولة MEC-20 أطلقت عشرة وكلاء تدقيق متوازيين (AUDIT-1 حتى AUDIT-10) غطوا المنتج والبنية والخلفية وقاعدة البيانات والواجهة وتجربة الاستخدام والأمن والأداء و DevOps وضمان الجودة، وتقاريرهم في مجلد research/audit شكلت خط الأساس الذي بنى عليه وكلاء هذه الجولة إعادة التحقق — يُشار لهم أدناه بـ«مساندة MEC-20») حيثما استند إلى أدلتهم.

## الفريق 01 — هندسة البرمجيات الشاملة

لم يُطلق وكلاء مستقلون لهذا الفريق؛ نفذ المنسق الرئيسي التنفيذ المباشر: 13 ملقاً جوهرياً غُذلت (جدول 4) عبر تحرير موضعي مضبوط، مع بناء واختبار انحدار موحد. (مساندة MEC-20: وكيل AUDIT-2 للبنية والأخطاء الكامنة)

| #  | الدور                     | الحالة الفعلية  | النطاق المنفذ والملاحظات                                               |
|----|---------------------------|-----------------|------------------------------------------------------------------------|
| 01 | قائد فريق الهندسة الشاملة | عُطي ضمن المنسق | تخطيط الدفعات وملكية الملفات وتنسيق التكامل — سجل العمل موثق زمنياً    |
| 02 | مهندس واجهة أول           | عُطي ضمن المنسق | page.tsx و store.tsx و layout.tsx: بحث عربي وقائمة انتظار وسيو ووصولية |
| 03 | مهندس خلفية أول           | عُطي ضمن المنسق | مسار waitlist جديد + إعادة كتابة wallet قراءة-فقط و ETag كتالوج        |

| #  | الدور                   | الحالة الفعلية  | النطاق المنفذ والملاحظات                                           |
|----|-------------------------|-----------------|--------------------------------------------------------------------|
| 04 | مهندس تكامل وواجهات     | عُطي ضمن المنسق | حارس الوضع الحي لمنع محاكاة الموردين غير المدعجين (G-B0)           |
| 05 | أخصائي React/Next.js    | عُطي ضمن المنسق | بناء 20 مسارًا نظيفًا + سلوك عميل ثلاثي الحالات مع تحقق متصفح      |
| 06 | خبير TypeScript وتصميم  | عُطي ضمن المنسق | tsc صفر أخطاء + أنواع CatalogChain/CatalogProdu الموسعة Ct         |
| 07 | مهندس منطق أعمال        | عُطي ضمن المنسق | قواعد الموجّه (هامش/رميد/قاطع/حارس) في engine.ts مع تعليقات مرجعية |
| 08 | مهندس مصادقة وتدفقات    | عُطي ضمن المنسق | نموذج ملكية الجوال الموحد على الطلبات وقائمة الانتظار والمحفظة     |
| 09 | أخصائي إعادة هيكلة ودين | جزئي ضمن المنسق | حجب ref وتوحيد الشكل؛ يبقى store.tsx ملفًا كبيرًا موثلاً للتفكيك   |
| 10 | مهندس تكامل برمجي       | عُطي ضمن المنسق | اندماج 13 ملفًا في بناء واحد و39 اختبار اندماج ثم نشر متحقق        |

## الفريق 02 — بنية الأنظمة والمنصة

لم يُطلق وكلاء مستقلون؛ غطى المنسق النطاق مباشرة مستندًا لتدقيق البنية في الجولتين. (مساعدة MEC-20: وكيل (AUDIT-2)

| #  | الدور              | الحالة الفعلية  | النطاق المنفذ والملاحظات                                                    |
|----|--------------------|-----------------|-----------------------------------------------------------------------------|
| 11 | قائد فريق البنية   | عُطي ضمن المنسق | قرارات الحفاظ على البنية لإعادة كتابة ولا خدمات مصغرة) موثقة المبرر         |
| 12 | أخصائي بنية مؤسسية | عُطي ضمن المنسق | مراجعة أثر الحارس الحي على عقد sandbox/live الوضعين                         |
| 13 | مهندس أنظمة موزعة  | غير مُطبق نطاقه | نظام أحادي النسخة بقرار موثق — حاجة موثقة للوزع في الحمل الحالي             |
| 14 | أخصائي DDD         | عُطي ضمن المنسق | حدود النطاقات في مكتبات الأعمال (محرك/محفظة/كتالوج) محفوظة بلا تسرب         |
| 15 | مراجع بنية برمجية  | عُطي ضمن المنسق | مراجعة قبل/بعد لكل تعديل مع تعليقات مرجعية بالملف والسطر                    |
| 16 | مهندس بنية تكامل   | عُطي ضمن المنسق | عقد الموردين في RouteChain (externalId) وعقد الاستجابات الموحدة             |
| 17 | مهندس توسع وسعة    | جزئي            | connection_limit=5 ومعالجة الانسداد الرأسي؛ دراسة النسخ الثانية مؤجلة بقرار |
| 18 | خبير معايير وأنماط | عُطي ضمن المنسق | أنماط حراس موحدة عبر المسارات وتحويلات مُدارة بإصدار                        |
| 19 | أخصائي حدود ووحدات | عُطي ضمن المنسق | صفر استيراد دائري محفوظ وفصل / عن intel/ مؤكد بعد إزالة الرابط              |
| 20 | مهندس حوكمة بنية   | عُطي ضمن المنسق | كل قرار جوهري موثق (قبل/بعد) في التقرير وسجل العمل                          |

### الفريق 03 — قاعدة البيانات وهندسة البيانات وAI

لم يُطلق وكلاء مستقلون؛ نغذ المنسق الترحيل والتحقق مباشرة. (مساندة MEC-20: وكيل AUDIT-4 بتدقيق قاعدة كامل)

| #  | الدور                    | الحالة الفعلية    | النطاق المنفذ والملاحظات                                         |
|----|--------------------------|-------------------|------------------------------------------------------------------|
| 21 | قائد فريق البيانات       | عُطي ضمن المنسق   | إدارة ترحيل 001 من التصميم إلى التحقق البعدي مع بروتوكول أمان    |
| 22 | أخصائي Postgres/Supabase | عُطي ضمن المنسق   | ترحيل تراكمي آمن + تحقق RLS/anon قبل وبعد + توثيق المحجوز للمالك |
| 23 | مهندس أداء قواعد         | عُطي ضمن المنسق   | تحويل 5432 → pgbouncer بـ بقاء مصفوفة معاملات موثقة (قسم ج)      |
| 24 | مهندس سلامة وترحيلات     | عُطي ضمن المنسق   | أول ترحيل مُدار بإصدار بشرط IF NOT EXISTS وتراجع موثق            |
| 25 | أخصائي هندسة بيانات      | عُطي ضمن المنسق   | تعبئة 37 منتجًا بأسماء بديلة مع تحقق 37/37                       |
| 26 | خبير تحليلات ونمذجة      | عُطي ضمن الوكيل E | حسابات الهوامش والتوزيعات على بيانات القاعدة الفعلية             |
| 27 | مهندس أنظمة AI/ML        | لم يُنفذ          | لا مكون ML في المنتج — يُوثق كمجال مستقبلي بلا ادعاء             |
| 28 | مهندس تكامل LLM          | لم يُنفذ          | لا تكامل LLM في نطاق هذه الجولة؛ منتجات AI تُشترى لا تُبنى       |
| 29 | أخصائي بحث متجهي         | غير مُطبق نطاقه   | بحث نمي عربي كافٍ ومُتحقق؛ المتجهي خارج الحاجة الموثقة           |
| 30 | مهندس حوكمة وخصوصية      | عُطي ضمن المنسق   | صفحة خصوصية منشورة + بيانات شخصية خارج الجوال والدفع             |

### الفريق 04 — الأمن السيبراني وحماية المعلومات

إطلاق فعلي: الوكيل MEC-21-C (أمني، إعادة تحقق مستقلة) عمل بالتوازي مع الخمسة؛ ثم نغذ المنسق التحصينات التي أوصى بها. (مساندة MEC-20: وكيل AUDIT-7)

| #  | الدور                 | الحالة الفعلية               | النطاق المنفذ والملاحظات                                        |
|----|-----------------------|------------------------------|-----------------------------------------------------------------|
| 31 | قائد فريق الأمن       | نُفذ — إطلاق فعلي (MEC-21-C) | قاد إعادة التحقق الشاملة بتسع مناطق ووُثق الحكم النهائي         |
| 32 | مهندس أمن تطبيقات     | نُفذ — إطلاق فعلي (MEC-21-C) | اختبارات صندوقية سوداء منخفضة الأثر محليًا وإنتاجيًا (GET/HEAD) |
| 33 | مهندس أمن سحابي       | عُطي ضمن المنسق              | تدقيق متغيرات Railway وتحديث skipDeploys وأمن سكوب الرمز        |
| 34 | أخصائي هوية وصلاحيات  | عُطي ضمن الوكيل C + المنسق   | إثبات الملكية على الطلبات/الانتظار + نموذج الجوال الموثق مخاطره |
| 35 | أخصائي RLS وأمن قواعد | عُطي ضمن المنسق              | تحقق مباشر RLS 10/10 وanon صفر قبل وبعد الترحيل                 |
| 36 | أخصائي نمذجة تهديدات  | نُفذ — إطلاق فعلي (MEC-21-C) | نموذج الأصول والحدود والجهات الفاعلة والمسار المالي             |
| 37 | مهندس مراجعة كود آمنة | عُطي ضمن المنسق              | مراجعة تغييرات الأمان سطرًا بسطر قبل الدفع مع فحص أنماط         |

| #  | الدور                       | الحالة الفعلية               | النطاق المُنقذ والملاحظات                                             |
|----|-----------------------------|------------------------------|-----------------------------------------------------------------------|
| 38 | أخصائي تقييم ثغرات          | نُفذ — إطلاق فعلي (MEC-21-C) | IDOR وتزييف XFF (190 طلبًا) وتلاعب أسعار وحقق — بلا اختبارات تخريب    |
| 39 | مهندس حماية أسرار           | عُطي ضمن C + المنسق          | كشف ارتباط التاريخ البعيد بالأسرار + تنقية + تدوير ADMIN_TOKEN        |
| 40 | أخصائي امتثال وجهازية حوادث | جزئي                         | سجل مخاطر متبقية وخطة تدوير؛ يبقى playbook حوادث رسمي للجولات القادمة |

## الفريق 05 — إدارة المنتج واستراتيجية الأعمال

إطلاق فعلي: الوكيل MEC-21-E (جاهزية أعمال) بالتوازي؛ (مساندة MEC-20: وكيل 1-AUDIT منتج)

| #  | الدور                     | الحالة الفعلية               | النطاق المُنقذ والملاحظات                                          |
|----|---------------------------|------------------------------|--------------------------------------------------------------------|
| 41 | قائد فريق المنتج والأعمال | نُفذ — إطلاق فعلي (MEC-21-E) | قيادة تقييم الجاهزية بمعايير معلنة ودرجات مبررة بالأدلة            |
| 42 | مدير المنتج               | نُفذ — إطلاق فعلي (MEC-21-E) | خريطة 18 رحلة مستخدم فُحصت فعليًا (17 ناجحة)                       |
| 43 | محلل أعمال                | نُفذ — إطلاق فعلي (MEC-21-E) | آليات النموذج المالي وتدفق الأموال والقيود الحاكمة                 |
| 44 | مهندس متطلبات             | عُطي ضمن الوكيل E            | تحويل وعد التذييل إلى متطلبات قابلة للفحص (سجل دائم — أنجز)        |
| 45 | مهندس عمليات أعمال        | عُطي ضمن الوكيل E            | فحص مزامنة الاستخدام وإدارة المخزون اليومية وفجواتها               |
| 46 | أخصائي عمليات منتج        | جزئي                         | لوحة إدارة موجودة (sync/stats/costs): أدوات استرداد/بحث عميل مُجلة |
| 47 | محلل أبحاث سوق            | جزئي                         | استند لاستخبارات الموردين الموجودة: بحث سوق خارجي خارج النطاق      |
| 48 | استراتيجي نموذج وتسييل    | نُفذ — إطلاق فعلي (MEC-21-E) | تحليل هوامش 37 منتجًا وإيجاد الفئة الأعلى ربحية ببيانات فعلية      |
| 49 | أخصائي تحليلات منتج       | لم يُنفذ — محجوب             | صفر تحليلات مثبتة: يتطلب قرار المالك بمزود (قسم ف)                 |
| 50 | محلل جاهزية تجارية        | نُفذ — إطلاق فعلي (MEC-21-E) | درجة 25% حية بمعايير معلنة + قائمة فجوات مُهيكل                    |

## الفريق 06 — تجربة الاستخدام والتصميم والعربية والوصولية

إطلاق فعلي: الوكيل MEC-21-A (إعادة تدقيق UX/RTL بعد إصلاح CSS) بالتوازي؛ ثم نُفذ المنسق حزمة الإصلاح. (مساندة MEC-20: وكيل 6-AUDIT)

| #  | الدور               | الحالة الفعلية               | النطاق المُنقذ والملاحظات                           |
|----|---------------------|------------------------------|-----------------------------------------------------|
| 51 | قائد فريق UX/UI     | نُفذ — إطلاق فعلي (MEC-21-A) | قاد إعادة التدقيق البصري الكاملة بجلسة متصفح معزولة |
| 52 | أخصائي تصميم واجهات | عُطي ضمن الوكيل A            | توثيق الحالة البصرية بالأنماط المحسوبة عبر 21 لقطة  |
| 53 | باحث تجربة          | عُطي ضمن الوكيل A            | رحلات فعلية بجوال جديد وطلبين حقيقيين في sandbox    |

| #  | الدور                        | الحالة الفعلية               | النطاق المنفذ والملاحظات                                        |
|----|------------------------------|------------------------------|-----------------------------------------------------------------|
| 54 | أخصائي تصميم تفاعل           | عُطي ضمن الوكيل A            | حالات التحميل/الفراغ/الخطأ/النجاح والمخطط الرباعي للسداد        |
| 55 | مهندس نظام تصميم             | عُطي ضمن المنسق              | هوية زمردية موحدة موسعة للأيقونات وصورة المشاركة الجديدة        |
| 56 | أخصائي عربية و RTL           | نُفذ — إطلاق فعلي (MEC-21-A) | تحقق bidi مقيس (هندسة المدى) + إصلاح الأسهم + البحث العربي حيًا |
| 57 | مهندس تجربة جوال             | عُطي ضمن الوكيل A            | 844×390 بلا فائض أفقي + أهداف لمس معالجة بالأولوية              |
| 58 | أخصائي وصولية WCAG           | عُطي ضمن A + المنسق          | تباين aria وتركيز ولوحة مفاتيح — 44px كاملة مؤجلة جزئيًا بتوثيق |
| 59 | أخصائي اختبار قابلية استخدام | عُطي ضمن الوكيل A            | إكمال شراء كامل بلوحة المفاتيح وحدها مُثبت                      |
| 60 | مراجع اتساق بصري             | عُطي ضمن الوكيل A            | تكافؤ محلي/إنتاجي مؤكد بالنمط واللقطات                          |

## الفريق 07 — الأداء والسرعة والموثوقية

إطلاق فعلي: الوكيل MEC-21-D (قياسات أداء) بالتوازي؛ ثم نُفذ المنسق إصلاح قاعدة الأداء الأهم. (مساندة MEC-20: وكيل AUDIT-8)

| #  | الدور                         | الحالة الفعلية               | النطاق المنفذ والملاحظات                                                       |
|----|-------------------------------|------------------------------|--------------------------------------------------------------------------------|
| 61 | قائد فريق الأداء              | نُفذ — إطلاق فعلي (MEC-21-D) | قاس 47 استدعاءً إنتاجيًا وثق الجدول التفاضلي الكامل قبل/بعد                    |
| 62 | أخصائي أداء واجهة             | عُطي ضمن الوكيل D            | تحليل حزم المسارين وأوزان الخطوط وETag (نُفذ 304)                              |
| 63 | مهندس أداء خلفية              | عُطي ضمن D + المنسق          | تحليل جذري لزمّن الصفحة وتحويله من 959~ إلى 144 مللي ثانية                     |
| 64 | أخصائي تحسين استعلامات        | عُطي ضمن المنسق              | مراجعة الفهارس السبعة عشر الساخنة (مأمدة) + اتصال limit=5                      |
| 65 | مهندس حمل وإجهاد              | لم يُنفذ — بقرار أمان        | اختبارات الحمل ممنوعة على الإنتاج الحي بقواعد الجولة؛ موثقة للجولات ببيئة تحمل |
| 66 | أخصائي تخزين وزمن استجابة     | نُفذ — إطلاق فعلي (MEC-21-D) | تحقق سلوك SWR باردًا/دافئًا + توثيق إزالة هاوية الـ 2.6 ثانية                  |
| 67 | أخصائي موثوقية                | عُطي ضمن الوكيل D            | زوال الانسداد الراشي + قاطع الدائرة الفعلي + مسار الصحة العميق                 |
| 68 | مهندس مراقبة ورصد             | جزئي                         | صحة عميقة + سجلات خطأ منظمة؛ لوحة مقاييس خارجية مؤجلة                          |
| 69 | مهندس موارد وكلفة             | جزئي                         | تقليم 48 → 14 تبعية موروث من MEC-20 وُثق؛ تحسين كلفة سحابية خارج النطاق        |
| 70 | أخصائي سرعة سير العمل الهندسي | عُطي ضمن المنسق              | توازي الوكلاء الخمسة + دفعة إصلاح منسقة ببناء واحد (قسم ج)                     |

## الفريق 08 — DevOps والسحابة وهندسة الإصدار

لم يُطلق وكلاء مستقلون؛ نُفذ المنسق كامل النطاق مباشرة (تاريخ GitHub المتنقي + متغيرات Railway + النشر المتعمد + CI). (مساندة MEC-20: وكيل AUDIT-9)

| #  | الدور                       | الحالة الفعلية  | النطاق المنفذ والملاحظات                                                                           |
|----|-----------------------------|-----------------|----------------------------------------------------------------------------------------------------|
| 71 | قائد فريق DevOps والإصدار   | عُطي ضمن المنسق | تنسيق الإصدار الثلاثي<br>نشر/Git/DB (نشر) كعمليّة واحدة بترتيب<br>موثّق                            |
| 72 | مهندس CI/CD                 | عُطي ضمن المنسق | CI أخضر على f80c040<br>(success 13:34Z) وتوثيق نشر<br>CI فاشل أولى                                 |
| 73 | أخصائي مستودع وفروع         | عُطي ضمن المنسق | قائمة بيضاء + دفع قوة بيتيمه +<br>تحقق API بعدي (التزام واحد)                                      |
| 74 | مهندس بنية سحابية           | عُطي ضمن المنسق | تدقيق متغيرات الخدمة السبعة<br>وتحديث اثنين بترتيب<br>skipDeploys                                  |
| 75 | أخصائي نشر Vercel/ويب       | غير مُطبق نطاقه | الاستضافة على Railway بقرار قائم؛<br>لا حساب Vercem متاح — N/A                                     |
| 76 | مهندس عمليات Supabase       | عُطي ضمن المنسق | ترحيل مُدار + تحقق بعدي + توثيق<br>ما يتطلب Dashboard للمالك                                       |
| 77 | أخصائي بنية ككود            | جزئي            | ترحيلات SQL مُدارة بإصدار؛ IAC<br>كامل خارج نطاق الجولة الحالية                                    |
| 78 | مهندس إصدارات وترقيم        | عُطي ضمن المنسق | التزام بيتيم موصوف + وسم الجولة<br>MEC-21 في الرسائل والسجلات                                      |
| 79 | أخصائي نسخ احتياطي واسترداد | جزئي            | تراجع نشر دون 5 دقائق<br>(deploymentRedeploy) +<br>تراجع ترحيل موثّق؛ نسخ DB دورية<br>مؤجلة للمالك |
| 80 | مهندس عمليات إنتاج          | عُطي ضمن المنسق | تحقق إنتاجي 34/34 + مراقبة صحة<br>+ جهوزية استجابة حوادث                                           |

## الفريق 09 — التسويق والنمو والاستراتيجية التجارية

إطلاق فعلي: الوكيل MEC-21-B (أول تدقيق نمو/سيو في تاريخ المشروع) بالتوازي؛ ثم نغذ المنسق حزمة الانتصارات السريعة.

| #  | الدور                      | الحالة الفعلية               | النطاق المنفذ والملاحظات                                         |
|----|----------------------------|------------------------------|------------------------------------------------------------------|
| 81 | قائد فريق النمو والتجاري   | نُغذ — إطلاق فعلي (MEC-21-B) | أول بطاقة سيو (10/25 → 23/25)<br>و خارطة نمو بأولويات مبررة      |
| 82 | أخصائي استراتيجية تسويق    | عُطي ضمن الوكيل B            | تقييم ملائمة الدفع العملائي للسوقين<br>وقنوات النمو المتاحة      |
| 83 | أخصائي تموضع ورسائل        | عُطي ضمن الوكيل B            | فحص وضوح القيمة في 5 ثوانٍ<br>ورسائل الثقة بالعربية              |
| 84 | أخصائي SEO ونمو عضوي       | نُغذ — إطلاق فعلي (MEC-21-B) | تدقيق 25 بندًا فنيًا وتنفيذ 13 إصلاحًا<br>حيًا (قسم ط)           |
| 85 | أخصائي تسويق محتوى         | لم يُنغذ                     | لا مدونة ولا صفحات محتوى — موثّق<br>كفرصة قادمة بعد صفحات المنتج |
| 86 | أخصائي إعلانات مدفوعة      | لم يُنغذ — محجوب             | الإعلان قبل التحليلات ودعم حي غير<br>مسؤول؛ موثّق شرطه (قسم ف)   |
| 87 | أخصائي تحسين تحويل CRO     | جزئي ضمن B + المنسق          | احتكاك القمع موثّق؛ نموذج الشراء<br>بحقل واحد مؤكد كنقطة قوة     |
| 88 | أخصائي استبقاء العملاء     | جزئي                         | كاش باك وقائمة انتظار كأدوات<br>استبقاء حية؛ برامج ولاء مستقبلاً |
| 89 | أخصائي مبيعات وزهّاب للسوق | جزئي ضمن الوكيل E            | تقييم جاهزية البيع الفعلي وحواجزها<br>الثلاثة الموثقة            |

| #  | الدور                 | الحالة الفعلية   | النطاق المنبذ والملاحظات                                      |
|----|-----------------------|------------------|---------------------------------------------------------------|
| 90 | محلل تسعير ونمو إيراد | عُطِيَ ضمن E + B | تحليل التسعير الجغرافي الحي وهوية الهوامش القصوى بفئة AI/SaaS |

## الفريق 10 — ضمان الجودة والاختبار والتحقق المستقل

لم يُطلق وكلاء مستقلون لهذا الفريق؛ نَقَدَ المنسق الاختبارات والتحقق المستقل مباشرة (73 فحصًا موثقًا). (مساندة MEC-20: وكيل 10-AUDIT بإعادة تحقق 38 فحصًا)

| #   | الدور                         | الحالة الفعلية        | النطاق المنبذ والملاحظات                                   |
|-----|-------------------------------|-----------------------|------------------------------------------------------------|
| 91  | قائد فريق الجودة والتحقق      | عُطِيَ ضمن المنسق     | تصميم بوابات الجودة: انحدار محلي 34 + تحقق إنتاجي 39       |
| 92  | أخصائي اختبارات وحدة          | لم يُنْقَذَ           | لا إطار اختبارات وحدة في المشروع — موثق كدين اختبار قادم   |
| 93  | مهندس اختبار تكامل            | عُطِيَ ضمن المنسق     | اختبارات تكامل فعلية عبر API (سداد → توجيه → تسليم → دفتر) |
| 94  | أخصائي اختبار شامل E2E        | عُطِيَ ضمن A + المنسق | رحلة شراء كاملة بمتصفح حقيقي + تحقق إنتاجي بصري            |
| 95  | مهندس اختبار API              | عُطِيَ ضمن المنسق     | 40 حالة API موثقة النتائج (نجاح/فشل/تخطي مسبب)             |
| 96  | أخصائي أتمتة متصفح ومتصفحات   | جزئي                  | Chromium آلي مُستخدم فعليًا؛ تغطية متصفحات متعددة مؤجلة    |
| 97  | أخصائي انحدار أمني            | عُطِيَ ضمن C + المنسق | إعادة اختبار كل إصلاح أمني بعد التنفيذ (قسم ز)             |
| 98  | أخصائي انحدار بصري ووصولية    | عُطِيَ ضمن A + المنسق | لقطات قبل/بعد + قياس تباين لقطات RTL وهندسة                |
| 99  | مهندس قبول إصدار وتحقيق إنتاج | عُطِيَ ضمن المنسق     | بوابة القبول: 34/34 إنتاجيًا قبل إعلان الإنجاز (قسم م)     |
| 100 | مراجع تدقيق وأدلة مستقل       | عُطِيَ ضمن المنسق     | تدقيق ذاتي للأدلة: كل ادعاء مربوط بمصدره أو موسوم بحدوده   |

## ف. الملخص التنفيذي على مستوى الفرق

تُلخَص الصفوف العشرة التالية التنفيذ الفعلي لكل فريق: عدد الوكلاء المُطلقين فعليًا، والتزامن الحقيقي، والنطاق المكتمل، والمعوقات. القراءة الصادقة المركزية: خمسة وكلاء متوازيون فعليًا أُطلقوا في دفعة واحدة (فرق 04 و05 و06 و07 و09) بينما عُطِيَ المنسق الرئيسي الفرق الخمسة الأخرى تنفيذًا مباشرًا (01 و02 و03 و08 و10) — فمحصيلة الإطلاقات الفعلية في هذه الجولة خمسة وكلاء فرعيين + منسق، مع الاستناد الموثق إلى عشرة وكلاء الجولة السابقة كخط أساس.

جدول 7: ملخص تنفيذ الفرق العشر

| الفريق         | وكلاء أُطلقوا فعليًا | التزامن           | النطاق المكتمل                   | المعوقات                       |
|----------------|----------------------|-------------------|----------------------------------|--------------------------------|
| 01 هندسة شاملة | 0 (تنفيذ منسق مباشر) | —                 | 13 ملغًا + بناء + انحدار 39      | لا شيء جوهريًا                 |
| 02 بنية أنظمة  | 0 (منسق)             | —                 | حفاظ البنية وقرارات موثقة        | لا حاجة وزع موثقة              |
| 03 بيانات AI   | 0 (منسق)             | —                 | ترحيل 001 + تحقق كامل            | Dashboard وAI خارجي بيد المالك |
| 04 أمن سيرانبي | 1 (MEC-21-C)         | متوازٍ ضمن الخمسة | إعادة تحقق 9 مناطق + كشف التاريخ | تدوير المفاتيح بيد المالك      |

| المعوقات                   | النطاق المكتمل                  | التزامن | وكلاء أطلقوا فعليًا | الفريق           |
|----------------------------|---------------------------------|---------|---------------------|------------------|
| صفر إيرداد حقيقي للتحليل   | 17/18 رحلة + هوامش + جاهزية 25% | متوازٍ  | 1 (MEC-21-E)        | 05 منتج وأعمال   |
| 44px الكاملة جزئية بتوثيق  | 18 تحقق + إصلاح كامل الدفعة     | متوازٍ  | 1 (MEC-21-A)        | 06 UX وعربية     |
| اختبار الحمل ممنوع أمانيًا | قياسات كاملة + إصلاح الجذر 87%  | متوازٍ  | 1 (MEC-21-D)        | 07 أداء وموثوقية |
| IAC خارج النطاق و Vercel   | تنقية Git + متغيرات + نشر CI +  | —       | 0 (منسق)            | 08 DevOps وإصدار |
| تحليلات وقرارات مالك معلقة | أول تدقيق سيو + 13 إصلاحًا حيًا | متوازٍ  | 1 (MEC-21-B)        | 09 نمو وتجاري    |
| لا إطار وحدة آلي بعد       | 73 فحصًا موثقًا عبر الجولتين    | —       | 0 (منسق)            | 10 جودة وتحقيق   |

التكامل بين الفرق جرى عبر ملكية ملفات صارمة لا تعديلات متزامنة على ملف واحد — كل تعديل تالٍ بُني على حالة سابقة ملتزمة). وبوابات تحقق موحدة (tsc و eslint) والبناء قبل أي دفع، ثم الانحدار، ثم التحقق الإنتاجي قبل إعلان أي إنجاز، وتوثيق مركزي تراكمي في سجل العمل جعل أدلة كل فريق متاحة للفريق التالي بلا إعادة اكتشاف.

## ق. الخطوات التالية وحالة الإنجاز النهائية

الخطوات التالية بترتيب الأثر، والخطوات الثلاث الأولى بيد المالك مباشرة: (1) تدوير مفاتيح ProdSeller و Supabase و DB و Railway من اللوحات المملوكة وإبلاغ GitHub Support لإجراء جمع مبكر للأسرار المؤقتة، (2) اختيار مزود رسائل SMS لتنفيذ W2 (مراقبة on-chain/webhook موقع)، (3) شحن رصيد حساب المورد لأول تشغيل حي محدود بمنتجات فئة AI/SaaS الأعلى هامشًا مع ترك Turgame خلف الحارس حتى اكتمال تكامله الحي ثم بيد الهندسة: صفحات منتج SSR، وترحيل حدود الحجم إلى middleware، وأتمتة اختبارات الانحدار داخل CI، ونطاق مخصص، ومزود تحليلات، ولوحة مالك خلف رمز.

جدول 8: الحالة النهائية للمهام الجوهرية

| المهمة                                                     | الحالة                                                             |
|------------------------------------------------------------|--------------------------------------------------------------------|
| تدقيق 5 وكلاء متوازنين + دمج النتائج                       | مكتملة ومتحقق منها                                                 |
| إصلاحات الأمان (محفظة + حارس حي + حدود معدل + مخزون ثلاثي) | مكتملة ومتحقق منها                                                 |
| حزمة النمو/السيو (13 إصلاحًا حيًا على الإنتاج)             | مكتملة ومتحقق منها                                                 |
| البحث العربي + ترحيل Supabase 001                          | مكتملة ومتحقق منها                                                 |
| إصلاح الأداء الجذري (144 → pgbouncer مللي ثانية)           | مكتملة ومتحقق منها                                                 |
| تنقية تاريخ GitHub + تدوير ADMIN_TOKEN                     | مكتملة ومتحقق منها (تدوير المفاتيح الأخرى بيد المالك)              |
| نشر Railway + تحقق إنتاجي 34/34                            | مكتملة ومتحقق منها                                                 |
| التقرير النهائي وسجل المئة دور                             | مكتملة (هذا المستند)                                               |
| تشغيل الوضع الحي (W2 + رصيد + تكامل Turgame)               | غير مبدوءة — بيد المالك ثم الهندسة                                 |
| تطبيق جوال أصلي                                            | غير موجود MOBILE APP NOT PRESENT — القنوات الفعلية: ويب متجاوب فقط |

الحكم النهائي الصادر: جولة MEC-21 مكتملة ومتحقق منها بالكامل في نطاقها المعلن — تدقيق متوازٍ فعلي بخمسة وكلاء بلا أي نشاط مفبرك، وتنفيذ حقيقي مثبت بالقياس لكل تحسين، وتنسيق Git و Supabase والنشر كإصدار واحد نظيف انتهى بإنتاج حي متحقق منه بـ 34 فحصًا ناجحًا. المشروع الآن في أقوى حالاته الموثقة على الإطلاق كهندسة، وتبقى فجواته الكبرى تجارية-تشغيلية بلا إيرداد حقيقي، والطريق إلى المرجع الاستراتيجي المعلن (مئة ألف دولار) يمر حصرًا عبر إغلاق بنود القسم ق بهذا الترتيب.